

Shadow IT and Shadow AI

CompTIA SecAI+: AI Security Certification Complete Exam Prep 2026 | Section 25: AI Risk Management

1. What Is Shadow AI — Beyond the Definition

Shadow AI refers to artificial intelligence tools and applications used within an organization without the knowledge, approval, or oversight of IT, security, or governance teams. The term inherits its name from shadow IT — the broader phenomenon of employees adopting unauthorized technology — but AI introduces a qualitatively different risk profile.

A shadow file-sync service risks data exposure on a passive storage platform. A shadow AI tool processes, analyzes, and generates content using that data. The inputs may be logged, retained for model training, stored in foreign jurisdictions, or accessible to third-party employees — without any security review having occurred. An employee who pastes a confidential contract into a public AI chatbot has effectively moved that data outside the organization's security perimeter through a fully functional, authorized-seeming channel. No breach occurred. No alert fired. Yet the data left.

Shadow AI is not primarily a malicious behavior. It is the predictable result of a speed mismatch: AI tools are developed and deployed in weeks; enterprise procurement takes months. Until organizations design faster, more responsive governance pathways, shadow AI will be a structural feature of the risk landscape.

2. Why Shadow AI Happens: The Procurement Gap

To manage shadow AI effectively, you must understand the rational calculation employees are making when they use unauthorized tools. A product manager who needs to analyze 2,000 customer support tickets faces a choice: submit a procurement request that may take six weeks to clear approval, or use ChatGPT right now and finish the analysis before lunch. An engineer seeking AI-assisted coding support can create a personal GitHub Copilot subscription and be productive immediately, without filing a ticket.

This is not negligence — it is optimization. Employees are trying to do their jobs well, and the official pathway is structurally slower than the unofficial one. The organizations that successfully reduce shadow AI adoption are the ones that create fast-track approval processes that compete with the shadow alternative on speed, not just on policy compliance. When the official path takes two to three weeks instead of six months, adoption of shadow tools drops significantly. Shadow AI is a procurement problem wearing a security mask.

3. The Samsung ChatGPT Incident — What Actually Happened

Real-World Incident — Samsung Electronics (2023): In early 2023, Samsung semiconductor engineers used ChatGPT to assist with debugging proprietary source code and summarizing confidential meeting notes. The inputs — including trade-secret-level technical details — were processed by OpenAI's servers, where they could have been used for model training under the then-current terms of service. Samsung reported at least three separate incidents within weeks of allowing ChatGPT access. Samsung subsequently banned the use of generative AI tools on corporate networks and devices. This incident illustrates the core shadow

AI risk: data exfiltration without breach, through a channel that employees perceived as a productivity tool. It also demonstrates how quickly containable risk can scale before a policy response catches up.

The Samsung case was notable because it was publicly disclosed — the vast majority of similar incidents in other organizations are never reported. Security teams should treat Samsung as a floor, not a ceiling, when estimating the prevalence of shadow AI data exposure in their own environments.

4. Data Exfiltration Without a Breach

Traditional data loss prevention frameworks were built around the concept of unauthorized exfiltration: a threat actor or malicious insider moving data through channels that were not supposed to transmit it. Shadow AI creates a new category — authorized exfiltration through unauthorized channels. The employee is authorized to access the data. The channel (internet, browser, personal account) is functional. Only the specific destination (an unapproved AI provider's API) is out of bounds — and most legacy DLP tools do not monitor for it.

Organizations need DLP rulesets specifically designed for AI tool usage. These include: network-layer monitoring for outbound connections to known AI API endpoints (api.openai.com, api.anthropic.com, generativelanguage.googleapis.com, etc.); content inspection rules that flag large text payloads sent to AI service domains; and behavioral analytics that identify when an employee's data-send volume to AI services is anomalous relative to peers or their own baseline. The challenge is dynamic: new AI services emerge constantly, and maintaining a comprehensive endpoint blocklist requires operational discipline.

5. Compliance Exposures by Regulatory Regime

Regulation	Requirement Implicated	Shadow AI Violation Scenario
GDPR (EU)	Personal data only processed by approved processors with a Data Processing Agreement (DPA) in place.	Employee uses unapproved AI tool to summarize EU customer correspondence containing PII — no DPA exists with the provider.
HIPAA (US)	Business Associate Agreement (BAA) required for any service handling Protected Health Information (PHI).	Healthcare worker uses public AI chatbot to summarize patient intake forms — no BAA in place with the AI provider.
SEC / FINRA (US)	Technology systems used in regulated activities must be approved, documented, and monitored.	Financial advisor uses personal AI subscription to draft client communications or analyze account data.
DORA (EU)	ICT systems used by financial entities must be subject to risk management and third-party oversight.	Bank employee uses unapproved AI tool for operational processes — tool not documented in third-party register.
Export Controls (EAR/ITAR)	Controlled technical data may not be shared with unauthorized foreign nationals or foreign systems.	Engineer pastes ITAR-controlled design specifications into a public AI tool hosted outside the US.

The compliance exposure scales with data sensitivity and regulatory environment. Healthcare and financial services organizations carry the highest exposure per shadow AI incident. A single HIPAA violation involving PHI can carry civil penalties up to \$1.9 million per violation category per year under the 2024 penalty tier adjustments.

6. Intellectual Property Exposure

Shadow AI creates IP risks that operate at two levels. First, when employees input proprietary code, trade secrets, business strategies, or unreleased product specifications into a public AI tool, that content enters the provider's system under their terms of service. If those terms permit using inputs for model training, proprietary information may be incorporated into a model that serves competitors.

Second, the ownership status of AI-generated outputs may be encumbered by the provider's terms. Several AI provider terms of service include licenses to use outputs in ways that may affect the organization's IP claims over work product generated using those tools. Engineering teams using personal AI coding assistants to write proprietary software may generate code to which the AI provider retains partial rights. Legal review of AI provider TOS documents is not an optional activity for organizations where IP is a core asset.

Memory Anchor — The Double Exposure: Shadow AI creates IP exposure in both directions. Your secrets may enter the AI system (inputs). The AI's outputs may carry the provider's IP claims back into your codebase. Think of it as a one-way valve that leaks in both directions.

7. Shadow AI as Invisible Attack Surface

When your security team does not know that employees are using a specific AI tool, they cannot protect against attacks targeting that tool. An attacker who discovers through OSINT that employees of your organization regularly use a particular AI productivity tool can direct attacks specifically at that tool's ecosystem: phishing campaigns that mimic the tool's interface, credential stuffing against the tool's login, API attacks against the tool's backend that expose query history.

Supply chain attacks against AI tool providers represent a particularly dangerous variant. Compromising an AI model to produce subtly malicious outputs — code with backdoors, summaries with omissions, recommendations that serve the attacker's interests — could affect your organization's operations before the tool is even known to your security team. In 2024, researchers demonstrated prompt injection attacks against AI coding assistants that caused the assistant to generate code containing hidden backdoors. If your threat model does not include attack surface you cannot see, it is incomplete.

From a MITRE ATT&CK perspective, shadow AI traffic can resemble T1119 (Automated Collection) and T1041 (Exfiltration Over C2 Channel) — large volumes of data moving to external endpoints at regular intervals. DLP and SIEM teams calibrated to detect these behaviors should be extended to cover AI service endpoints alongside traditional exfiltration channels.

8. Red Team Discovery: Finding Shadow AI in Your Environment

- Network traffic analysis — monitor for outbound connections to known AI API domains and IP ranges; review DNS query logs for AI service domains including emerging and niche providers.
- Browser extension inventory — many AI productivity tools are deployed as browser extensions that may not appear in software inventories; MDM-based extension audits reveal adoption not visible in network logs.
- Expense report review — personal AI subscriptions (monthly charges to OpenAI, Anthropic, GitHub, Midjourney, etc.) frequently appear in employee expense submissions before IT is aware of the tools.
- Employee surveys — direct questions about AI tool usage, designed to be non-punitive and focused on understanding rather than enforcement, often surface tools and use cases that technical discovery misses.
- Behavioral analytics — spikes in API call volume to AI endpoints during business hours, correlated with specific user or team patterns, indicate adoption of tools that may not appear in other inventories.
- Code repository scanning — search for AI provider SDK imports, API key patterns, and model invocation patterns in repositories to identify developer adoption of unauthorized AI services.
- Third-party app permission review — OAuth-connected applications authorized through employee accounts often include AI tools that bypassed procurement entirely.

9. Technical Controls: Layered Defense

Control Layer	Mechanism	Coverage Gap
Network layer blocking	Firewall rules block connections to known AI service IP ranges and domains.	New AI services, CDN-hosted endpoints, and domain changes require continuous blocklist updates.
SSL/TLS inspection	Proxy-based deep packet inspection identifies AI service traffic even over HTTPS.	Requires employee notification (legally mandated in many jurisdictions); may miss certificate pinning.
Browser extension management	MDM policies prevent installation of unapproved browser extensions on managed devices.	Personal devices, BYOD environments, and cellular connections bypass endpoint controls.
DLP with AI rulesets	Data loss prevention tools detect large text payloads sent to AI endpoints; alert on sensitive data patterns.	Requires current AI endpoint lists; encrypted traffic requires SSL inspection to inspect content.
Endpoint detection and response	EDR tools log and flag application-layer connections to AI services from managed endpoints.	Coverage limited to managed devices; does not address personal device or web-based access.

No single technical control is complete. Employees with personal devices, cellular connections, or sufficient motivation can circumvent any individual control. The value of layered controls is that they make uncontrolled shadow AI usage significantly harder and more detectable — not that they make it impossible. Technical controls must be accompanied by communication explaining their existence and

purpose, as surprise monitoring erodes employee trust and often triggers legal requirements in EU jurisdictions.

10. The Approved AI Catalog: Making Official the Easy Path

The most effective intervention against shadow AI is not restriction but provision. An approved AI catalog that gives employees access to tools meeting security, compliance, and IP requirements removes the primary motivation for shadow AI: the gap between what employees need and what the official pathway provides. Organizations with comprehensive approved catalogs report significant reductions in unauthorized tool adoption.

Effective catalogs share several characteristics: they cover a range of use cases (text generation, code assistance, data analysis, image generation, voice transcription); they are updated at a cadence that tracks the AI tool landscape rather than enterprise procurement cycles; they include per-tool guidance specifying exactly what employees can and cannot do with each approved tool; and they make tool access frictionless — approved tools accessible via SSO on day one, not after weeks of individual license provisioning.

Enterprise-grade options that organizations with existing vendor relationships may already have access to include Microsoft 365 Copilot for Business (enterprise data handling commitments, no training on customer data by default), GitHub Copilot for Business (code isolated from public model training), and Google Workspace AI add-ons (DPA-covered, GDPR-compliant configuration available). These tools were specifically designed to provide governed AI capabilities within enterprise data handling requirements.

11. Shadow Agentic AI: The Escalating Risk

The shadow AI risk profile is evolving with AI capability. Through 2023-2024, shadow AI primarily meant employees using text generation and code assistance tools — the risk was data input to the tool. In 2024-2025, employees began adopting agentic AI tools: systems that do not just generate content but take actions — scheduling, email management, code deployment, data processing, and web browsing on behalf of the user.

Anthropic's Model Context Protocol (MCP), released in November 2024, enables AI models to connect directly to enterprise data sources, APIs, and external services. By early 2025, hundreds of MCP servers were available for tools including Slack, GitHub, Jira, and Salesforce, enabling AI agents to take actions in those systems using the authenticated user's permissions. An employee using an unapproved agentic tool connected to Salesforce via MCP can authorize bulk data exports, mass email sends, or record modifications at a scale far beyond what any text generation tool could achieve.

Critical Distinction — Agentic Shadow AI: Traditional shadow AI leaks data passively (input to a chat interface). Agentic shadow AI can take irreversible actions at scale using the user's access rights across connected enterprise systems. Shadow agentic AI represents a materially higher risk category requiring specific governance attention.

12. Continuous Monitoring and Governance

Shadow AI is not a problem you solve once. New AI tools emerge weekly. Employee AI behavior evolves as tools become more capable. Attackers continuously identify new ways to exploit AI tool adoption. Effective shadow AI governance is designed around continuous adaptation rather than point-in-time policy.

The monitoring stack should include: network traffic analysis reviewed monthly for new AI service connections; expense report review as a standing process with AI subscription identification; quarterly employee surveys about AI tool usage with non-punitive framing; integration of AI-related security events into SOC threat intelligence feeds; and regular review of AI provider TOS changes as they occur — a provider changing its data retention or training use policy represents a material change in risk for currently approved tools.

Governance requires a clear organizational owner: whether a dedicated AI Center of Excellence, IT security, or the CISO's office, someone must have authority and accountability for the approved AI catalog, shadow AI monitoring, and incident response. Governance without clear ownership defaults to no governance in practice.

Key Terms Glossary

Term	Definition
Shadow AI	AI tools and applications used within an organization without the knowledge, approval, or oversight of IT, security, or governance teams.
Shadow IT	The broader phenomenon of employees adopting unauthorized technology outside of official IT procurement and governance processes.
Data Processing Agreement (DPA)	A legally binding contract between a data controller and a data processor specifying how personal data will be handled; required under GDPR before personal data may be sent to a third-party processor.
Business Associate Agreement (BAA)	A HIPAA-required contract between a covered entity and any third party that handles Protected Health Information (PHI) on its behalf.
DLP (Data Loss Prevention)	Technology tools and policies designed to detect and prevent unauthorized transfer of sensitive data outside an organization's security perimeter.
Agentic AI	AI systems that do not merely generate content but take autonomous actions — such as browsing the web, executing code, sending emails, or interacting with APIs — on behalf of a user.
Model Context Protocol (MCP)	An open protocol released by Anthropic in November 2024 that enables AI models to connect to and interact with external data sources, APIs, and services in a standardized way.
Approved AI Catalog	A curated list of AI tools that have been reviewed and approved by an organization's security, legal, and compliance teams, with defined usage parameters for each tool.
Supply Chain Attack (AI context)	A cyberattack targeting the AI tool or model itself — compromising the tool's outputs — rather than the organization directly, affecting all users of the compromised tool.
Fast-Track Procurement	An expedited AI tool review and approval process designed to reduce approval timelines, addressing the procurement-speed gap that drives

Quick Revision Checklist

- Shadow AI is AI tool usage without organizational approval — a procurement problem, not primarily a malicious behavior.
- The root cause is a speed gap: AI tool development takes weeks; enterprise procurement takes months.
- Samsung (2023) is the canonical public case — proprietary source code and meeting notes entered OpenAI systems via employee use.
- Primary data risk: exfiltration without breach — data leaves through a functional channel, not through an attack.
- GDPR requires a DPA before personal data may be sent to any processor; no DPA means likely violation even without a breach.
- HIPAA requires a BAA with any service handling PHI; public AI tools almost never have BAA coverage.
- IP risk is bidirectional: inputs may be trained on; outputs may carry provider IP claims.
- Red team discovery methods: network traffic, DNS logs, browser extensions, expense reports, employee surveys.
- Technical controls are layered and incomplete — no single control blocks all shadow AI; personal devices always create gaps.
- The approved AI catalog is the most effective control — make the official path faster and easier than the shadow alternative.
- Agentic shadow AI (tools connected via MCP to enterprise systems) is materially higher risk than text-generation shadow AI.
- Governance requires a named organizational owner with authority to approve, restrict, and respond to AI tool incidents.
- Monitoring must be continuous: new tools emerge constantly, and provider TOS changes affect risk of already-approved tools.

10 Exam-Based MCQs — Shadow IT and Shadow AI

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. Scenario: A financial services firm's SOC analyst discovers that multiple employees in the product team have been using ChatGPT through personal accounts to analyze customer feedback data. The CISO has been asked to brief the board on the company's response. The organization has no approved AI tools for this use case, and the procurement process for new software tools averages four months. What should the security team recommend FIRST?

- A) Immediately terminate the employees responsible for using ChatGPT.
- B) Implement network-layer blocking of all AI service endpoints.
- C) Audit all AI tool usage and establish a fast-track approval process.

D) Deploy SSL inspection across all corporate devices.

Answer: C **Explanation:** C is correct because shadow AI is a structural procurement problem — blocking tools without providing approved alternatives drives usage underground rather than eliminating it. A fast-track approval process plus an audit of current usage addresses root cause and gives the organization visibility. A is wrong because termination is disproportionate and does not address the systemic problem. B is wrong because network blocking is incomplete (personal devices, cellular access) and does not address the procurement gap that drives shadow AI adoption. D is wrong because SSL inspection is a monitoring control, not a governance solution, and may have legal implications.

Q2. Scenario: A data analyst at a European e-commerce company uses a public AI tool to generate summaries of customer complaint emails. The emails contain names, email addresses, and order histories of EU residents. The AI tool does not appear on the company's approved vendor list, and no contractual agreement exists with the provider. Which compliance violation has MOST likely occurred?

- A) HIPAA violation due to unauthorized processing of patient financial data.
- B) GDPR violation due to transfer of EU resident personal data to an unapproved processor.
- C) SOX violation due to use of unlicensed software in financial reporting.
- D) FISMA violation due to processing of government data on commercial infrastructure.

Answer: B **Explanation:** B is correct because GDPR requires a Data Processing Agreement (DPA) to be in place before personal data of EU residents may be sent to any third-party processor. Using an unapproved AI tool without a DPA constitutes a violation regardless of whether a breach occurred. A is wrong because HIPAA applies to PHI in healthcare contexts; the scenario involves EU customer personal data, not patient health data. C is wrong because SOX concerns financial reporting controls, not general software licensing. D is wrong because FISMA applies to federal government information systems, not commercial enterprise data.

Q3. Scenario: An engineer at a hospital system used a personal ChatGPT account to summarize physician notes for a quality improvement project. During an internal security review, this activity is discovered. The notes included patient names, dates of birth, and diagnosis codes. The hospital's CISO is assessing the incident. Which response is MOST appropriate for the immediate term?

- A) Block all AI service domains at the firewall to prevent further data exposure.
- B) Require employees to sign updated acceptable use policies before accessing the internet.
- C) Assess what data was input to the AI tool and whether a reportable breach occurred under applicable regulations.
- D) Terminate the subscription to the AI tool's enterprise plan.

Answer: C **Explanation:** C is correct because the immediate priority is understanding the scope of potential data exposure and determining regulatory obligations. Under HIPAA, a breach involving PHI may trigger mandatory breach notification within specific timeframes. Knowing what data entered the AI system is prerequisite to any other response decision. A is wrong because blocking AI services is a forward-looking control that does not address the data already input. B is wrong because policy updates address future behavior, not the current incident. D is wrong because the engineer used a personal account —

there is no enterprise subscription to terminate, and subscription management is not incident response.

Q4. Which of the following BEST describes the primary driver of shadow AI adoption in organizations?

- A) Employees deliberately bypassing security controls to exfiltrate data.
- B) A speed mismatch between AI tool availability and enterprise procurement timelines.
- C) Inadequate technical controls that fail to block AI service endpoints.
- D) Insufficient security training causing employees to underestimate risk.

Answer: B **Explanation:** B is correct because shadow AI is predominantly a rational response to the procurement gap — AI tools are available in days; enterprise approval processes take months. Employees use shadow AI to do their jobs, not to evade security. A is wrong because deliberate data exfiltration is a separate threat category; the vast majority of shadow AI adoption is motivated by productivity, not data theft. C is wrong because technical controls are a response to shadow AI, not its cause. D is wrong because training affects awareness at the margins but does not address the structural procurement gap that makes shadow AI adoption rational.

Q5. Which of the following shadow AI discovery methods is MOST likely to surface tools that have bypassed network monitoring entirely?

- A) DNS query log analysis for AI service domains.
- B) Review of employee expense reports for AI subscription charges.
- C) Firewall log analysis for outbound connections to AI API endpoints.
- D) Browser extension inventory via MDM policy enforcement.

Answer: B **Explanation:** B is correct because employees using AI tools through personal devices or cellular connections will not generate corporate network traffic or DNS queries. Expense report charges appear regardless of how the tool was accessed, surfacing subscriptions that bypassed all network-level monitoring. A is wrong because DNS query analysis only covers tools accessed through the corporate network. C is wrong for the same reason — firewall logs only capture corporate network traffic. D is wrong because MDM extension inventories only cover managed devices; personal devices are outside MDM scope.

Q6. Which statement BEST describes the IP risk created by shadow AI tools?

- A) Employees who use AI tools without approval lose copyright ownership of any outputs generated.
- B) Shadow AI tools may incorporate proprietary inputs into training data and may encumber outputs with provider IP claims.
- C) Organizations are liable for IP infringement if AI tools generate outputs similar to existing copyrighted works.
- D) AI provider terms of service uniformly prohibit use of tool outputs in commercial products.

Answer: B **Explanation:** B is correct because shadow AI creates IP risk in both directions: proprietary inputs may be used in model training, and outputs generated by the tool may be subject to IP licenses

retained by the provider under their terms of service. A is wrong because copyright ownership analysis is complex and jurisdiction-dependent; approval status does not automatically determine copyright ownership. C is wrong because while AI output copyright infringement is a real concern, it is distinct from shadow AI's IP risk — it applies to approved tools as well. D is wrong because AI provider TOS vary significantly; many enterprise-tier products explicitly disclaim training on customer data and grant full output rights to the user.

Q7. A healthcare organization wants to reduce shadow AI usage while enabling employees to use AI tools productively. Which approach is MOST effective?

- A) Implement comprehensive network blocking of all AI service endpoints.
- B) Issue a mandatory policy prohibiting AI tool use without prior written approval.
- C) Deploy an approved AI catalog with fast-track review and SSO-enabled tool access.
- D) Conduct quarterly security training on the risks of unauthorized AI tool usage.

Answer: C **Explanation:** C is correct because the most effective shadow AI control is providing a better alternative. An approved catalog with fast-track review and frictionless access (SSO) makes the official pathway competitive with shadow adoption on speed and convenience, addressing the root cause rather than just blocking it. A is wrong because network blocking is incomplete and does not address the underlying need. B is wrong because prohibitive policies that do not provide alternatives drive shadow usage underground rather than eliminating it. D is wrong because training improves awareness but does not address the structural procurement problem.

Q8. Which of the following BEST describes why agentic shadow AI represents a materially higher risk than text-generation shadow AI?

- A) Agentic AI tools have larger language models that process more data per query.
- B) Agentic AI tools are more expensive, increasing financial exposure for organizations.
- C) Agentic AI tools can take irreversible actions at scale using the user's enterprise access rights.
- D) Agentic AI tools generate outputs that are more likely to contain sensitive information.

Answer: C **Explanation:** C is correct because agentic AI systems connected to enterprise tools via protocols like MCP can autonomously take actions — bulk data exports, mass email sends, code commits, record modifications — using the authenticated user's permissions. These actions can be irreversible and scale instantly. Text-generation tools passively receive inputs; the risk is data entering the system. Agentic tools can also cause data to exit, systems to change state, and processes to execute at scale. A is wrong because model size is not the defining risk factor. B is wrong because financial cost is not a primary security risk dimension. D is wrong because output sensitivity is a risk for all AI tools, not distinctive to agentic systems.

Q9. Which MITRE ATT&CK techniques are MOST relevant when analyzing shadow AI network traffic from a defensive perspective?

- A) T1566 (Phishing) and T1078 (Valid Accounts)
- B) T1119 (Automated Collection) and T1041 (Exfiltration Over C2 Channel)

- C) T1195 (Supply Chain Compromise) and T1059 (Command and Scripting Interpreter)
- D) T1027 (Obfuscated Files or Information) and T1036 (Masquerading)

Answer: B **Explanation:** B is correct because shadow AI usage generates network traffic patterns that behaviorally resemble T1119 (Automated Collection) — systematic data being collected and sent to an external endpoint — and T1041 (Exfiltration Over C2 Channel) — large data volumes moving outbound to external infrastructure on regular schedules. DLP and SIEM rules calibrated for these techniques should be extended to cover AI service endpoints. A is wrong because phishing and valid accounts describe initial access, not data movement patterns. C is wrong because supply chain compromise and scripting interpreter describe different attack phases. D is wrong because obfuscation and masquerading describe attacker evasion techniques, not shadow AI traffic patterns.

Q10. An organization's existing AI acceptable use policy is not changing employee behavior. Which modification is MOST likely to improve compliance?

- A) Increase the severity of disciplinary consequences for policy violations.
- B) Require employees to re-read and sign the policy annually.
- C) Rewrite the policy to name specific prohibited behaviors, explain specific risks, and communicate it through channels employees actually use.
- D) Reduce the policy length to a single page so it is easier to read.

Answer: C **Explanation:** C is correct because research on policy effectiveness consistently shows that policies that name specific behaviors, explain the concrete risks behind restrictions, and reach employees through channels they actually use produce meaningfully better compliance. Real scenarios and named incidents (Samsung-type cases) significantly improve retention and behavioral response. A is wrong because punitive escalation without substantive policy improvement may increase concealment rather than compliance. B is wrong because annual re-signing is a compliance checkbox, not a behavior-change intervention; re-reading an unclear policy does not make it clearer. D is wrong because length is not the primary problem — a short abstract policy will not change behavior; a longer policy with concrete guidance and real examples outperforms a short abstract one.